YAHOO DATA BREACH

A CASE STUDY IN CYBERSECURITY

Timeline | Attack Vectors | Impact | Countermeasures

THE TWIN BREACHES

AUGUST 2013

Scale: 3 Billion Accounts (Every single user)

Discovery: Disclosed in Dec 2016.

Nature: State-sponsored actors compromised the database backup.

Largest breach in internet history.

LATE 2014

Scale: 500 Million Accounts

Discovery: Disclosed in Sept 2016.

Nature: Targeted attack using spear phishing and forged cookies.

Specific targeting of high-value individuals.

TIMELINE OF FAILURE

2013

Initial breach compromises all 3B accounts.

2014

Second breach hits 500M accounts via cookies.

2016

Yahoo publicly discloses both breaches.

2017

Verizon acquisition price cut by $350M.

ATTACK SURFACE

USER DATABASE

The primary target containing PII: Names, emails, phone numbers, and birth dates.

WEB COOKIES

Proprietary code for minting cookies allowed attackers to access accounts without passwords.

BACKUP SYSTEMS

Attackers targeted database backups which were less monitored than the live environment.

VECTOR: SPEAR PHISHING

The 2014 breach began with a classic **Spear Phishing** campaign.

- **Target:** Semi-privileged Yahoo employees.
- **Method:** Highly personalized emails containing malware.
- **Result:** Attackers gained entry to the internal network, allowing them to pivot to the user database.

VECTOR: FORGED COOKIES

PERSISTENCE MECHANISM

Once inside, attackers stole the source code used to mint authentication cookies.

This allowed them to forge valid cookies for any user account, effectively logging in as the victim without ever needing a password.

Key Lesson: Authentication tokens are as valuable as passwords.

IMPACT: THE SCALE

3.0 / **100%**

BILLION ACCOUNTS

OF USERBASE

Every single Yahoo account that existed in 2013 was compromised.

FINANCIAL & LEGAL FALLOUT

Verizon Acquisition

-$350 Million

Gavel

Class Action Settlement

$117.5 Million

SEC Fine

$35 Million

COUNTERMEASURES TAKEN

- **Invalidated Cookies:** Yahoo invalidated all forged cookies to force re-authentication.
- **Password Resets:** Forced password changes for all potentially affected users.
- **Encryption Upgrade:** Switched from the weaker MD5 to the robust bcrypt hashing algorithm.
- **Enhanced Security:** Implemented Multi-Factor Authentication (MFA) and hired a new CISO.

Q & A

Thank you.

IMAGE SOURCES

https://imgcdn.stablediffusionweb.com/2025/8/22/98daf527-73aa-46d0-a126-d75d387017fd.jpg

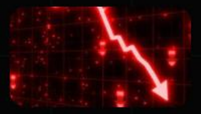
Source: stablediffusionweb.com

https://us.norton.com/content/dam/blogs/images/norton/am/spear-phishing-01.png

Source: us.norton.com

https://img.freepik.com/premium-psd/green-binary-code-rain-falling-3d-perspective-dark-grid-background-digital-matrix-style-png_1277163-1027.jpg

Source: www.freepik.com



https://i.ytimg.com/vi/3BlUItdCiQU/hq720.jpg?sqp=-oaymwEhCK4FEIIDSFryq4qpAxMIARUAAAAAGAElAADIQj0AgKJD&rs=AOn4CLBZvubzFtZkFAj5pyCUhF7ByYgBlg

Source: www.youtube.com

https://image.slidesdocs.com/responsive-images/background/legal-concept-judges-gavel-on-wooden-surface-with-copy-space-for-law-and-justice-image-powerpoint-background_9011718dfb__960_540.jpg

Source: slidesdocs.com

https://assets.techcircle.in/images/2016/07/handshaking1.jpg

Source: www.techcircle.in